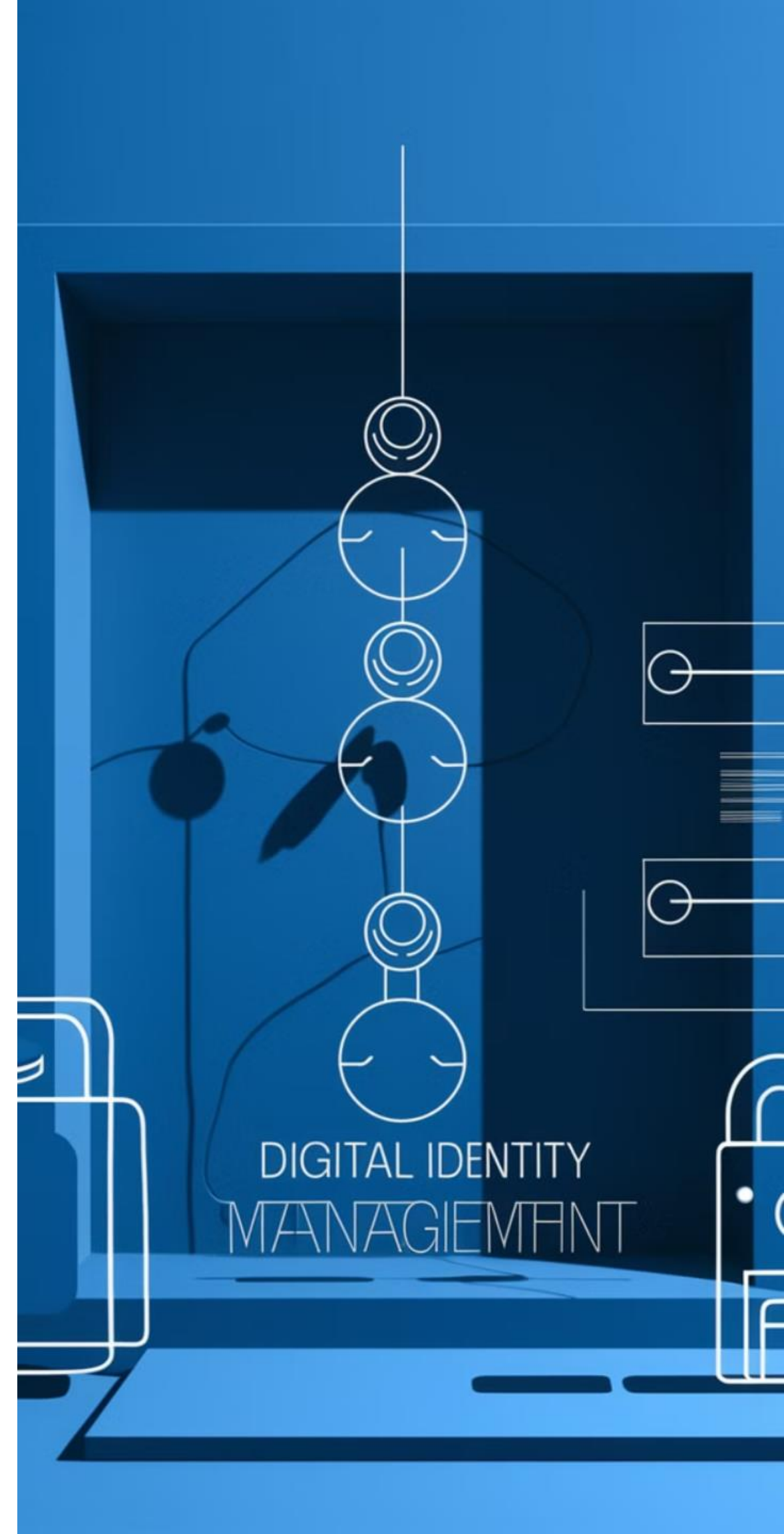


Manajemen Identitas dan Akses

Identitas adalah salah satu lapisan keamanan terpenting dalam organisasi modern. Identitas dan akun yang terhubung dengannya memungkinkan organisasi mengontrol siapa yang memiliki akses ke sistem dan layanan mereka.

 **by antamil said**





Apa Itu Identitas?

Definisi

Identitas adalah kumpulan klaim tentang subjek. Subjek biasanya orang, aplikasi, perangkat, sistem, atau organisasi.

Atribut

Identitas terkait dengan informasi tentang subjek, termasuk nama, usia, lokasi, atau jabatan.

Klaim Identitas

Subjek dapat mengklaim identitas melalui username, sertifikat, token, kunci SSH, atau smartcard.



Keamanan Pasangan Kunci

1

Risiko Utama

Pasangan kunci yang terekspos atau hilang dapat menjadi masalah keamanan besar.

2

Kesalahan Umum

Mengunggah kunci privat ke repositori kode publik adalah masalah yang relatif umum.

3

Praktik Terbaik

Smartcard yang dirancang dengan baik biasanya menghasilkan pasangan kunci pada kartu untuk mencegah penyalinan.

Autentikasi dan Otorisasi

Autentikasi

Membuktikan bahwa identitas adalah milik Anda. Teknologi autentikasi memastikan bahwa subjek adalah siapa yang mereka klaim.

Otorisasi

Memverifikasi apa yang Anda miliki akses. Otorisasi memungkinkan Anda mengakses sumber daya berdasarkan apa yang diizinkan.

Teknologi Autentikasi dan Otorisasi

1

EAP

Extensible Authentication Protocol adalah kerangka kerja autentikasi yang umum digunakan untuk jaringan nirkabel.

2

RADIUS

Sistem AAA umum untuk perangkat jaringan, jaringan nirkabel, dan layanan lainnya.

3

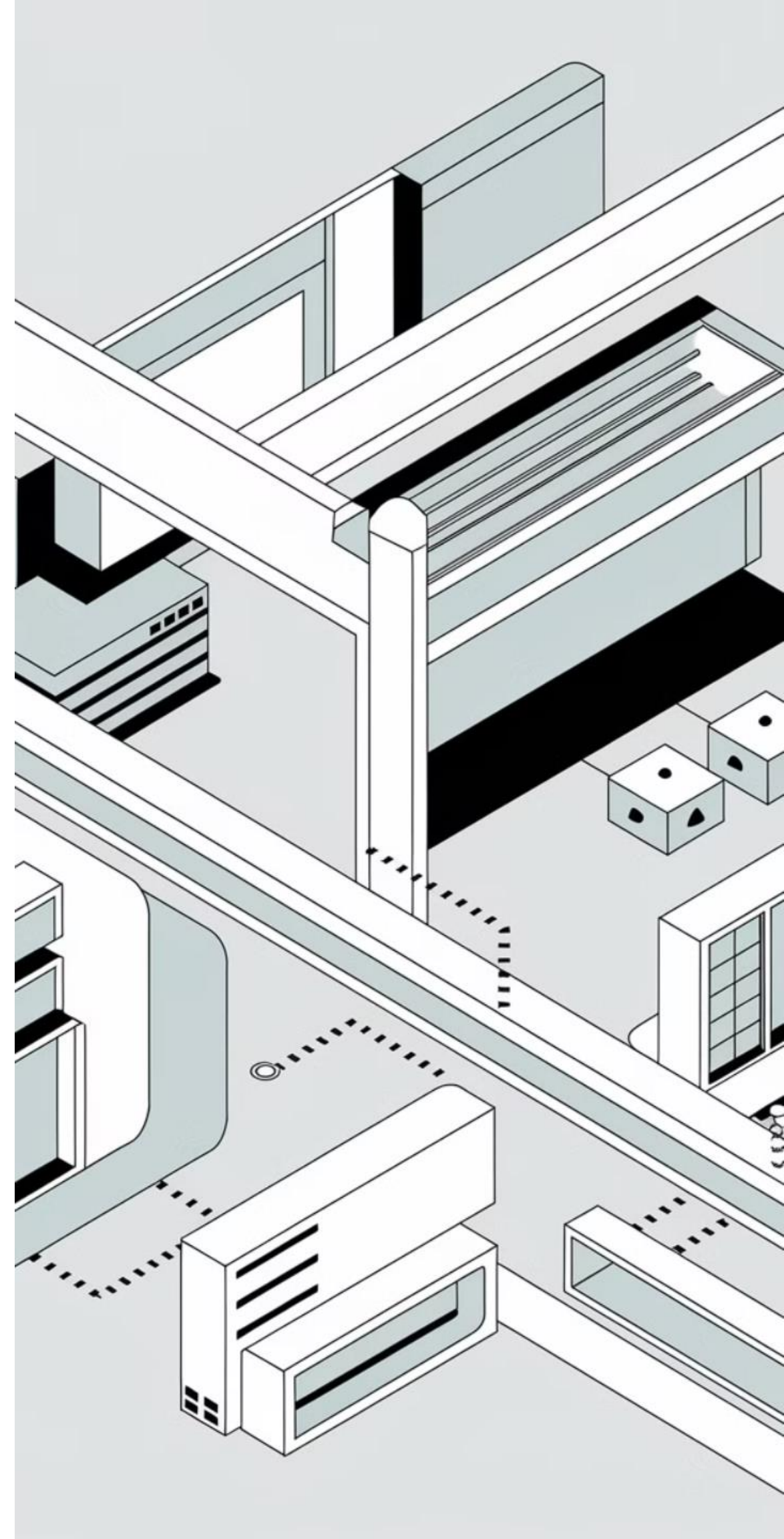
Kerberos

Protokol untuk mengautentikasi permintaan layanan antara host terpercaya melalui jaringan yang tidak terpercaya.

4

SAML, OAuth

Standar terbuka untuk pertukaran informasi autentikasi dan otorisasi, umum digunakan untuk SSO.



Metode Autentikasi

1 **Multi-faktor**
Kombinasi beberapa faktor autentikasi

2 **Biometrik**
Sesuatu yang Anda miliki secara fisik

3 **Token/OTP**
Sesuatu yang Anda miliki

4 **Password**
Sesuatu yang Anda ketahui

Setelah mengklaim identitas dengan menyediakan username atau sertifikat, langkah berikutnya adalah membuktikan bahwa identitas tersebut milik Anda. Password tetap menjadi cara autentikasi paling umum, namun memiliki beberapa kelemahan.

Praktik Terbaik Password



Panjang

Menekankan panjang daripada kompleksitas untuk mencegah serangan brute-force.



Kompleksitas

Memastikan penggunaan karakter set yang lebih besar untuk serangan brute-force.



Pembatasan Penggunaan Ulang

Mencegah pengguna mengatur ulang password ke password sebelumnya yang mungkin terekspos.



Tanggal Kedaluwarsa

Memastikan password tidak digunakan untuk jangka waktu yang lama.



Pengelola Password



Aplikasi Khusus

Pengelola password seperti 1Password dan Bitwarden membantu pengguna membuat dan menyimpan password yang aman.



Windows Credential Manager

Dapat menyimpan dan mengelola kredensial web dan Windows.



Apple Keychain

Menyinkronkan ke iCloud Apple dan menyinkronkan password di seluruh perangkat Apple.

A person's hands are shown holding a silver smartphone in the left hand and a small black security key on a ring in the right hand. The background is a modern building with large glass windows and a dark frame.

Autentikasi Tanpa Password

1

Kunci Keamanan

Perangkat keras yang mendukung password satu kali, kriptografi kunci publik, dan protokol keamanan seperti FIDO.

2

Biometrik

Menggunakan faktor yang mengandalkan tubuh Anda seperti sidik jari atau pengenalan wajah.

3

FIDO2

Standar autentikasi terbuka yang mendukung spesifikasi W3C Web Authentication dan CTAP.

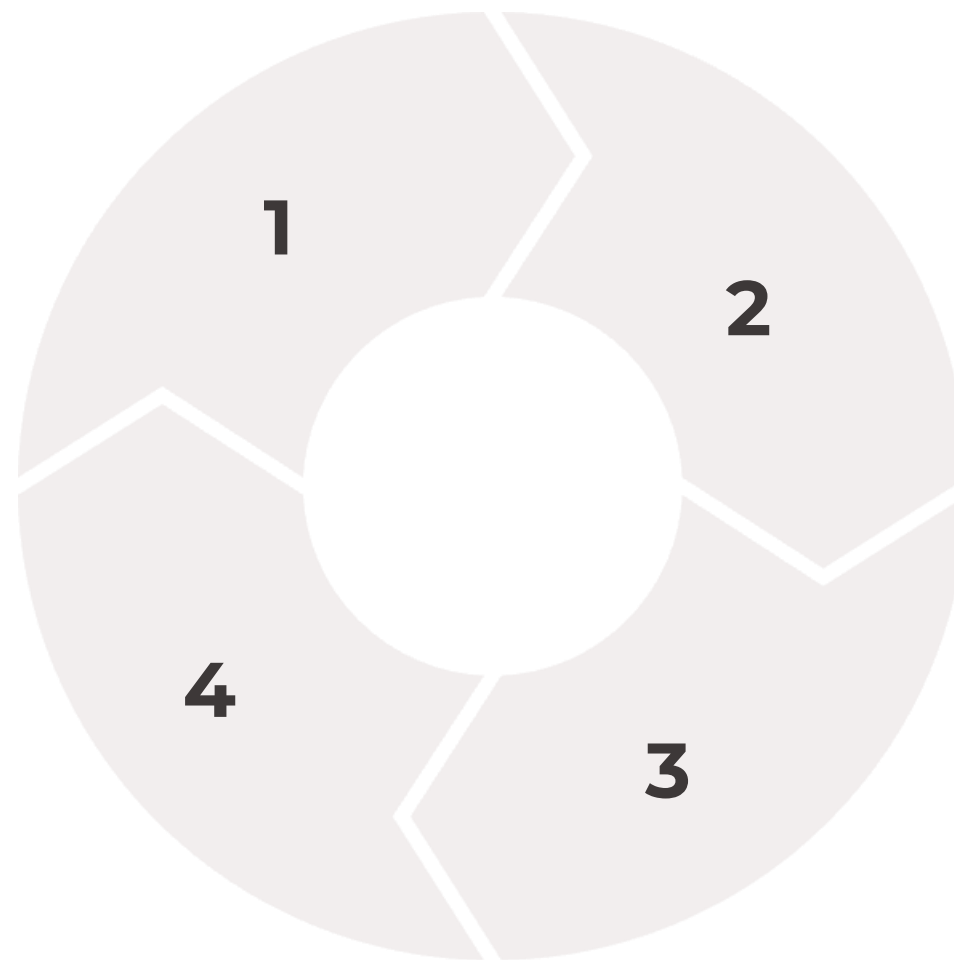
Autentikasi Multi-faktor (MFA)

Sesuatu yang Anda Ketahui

Password, PIN, atau jawaban pertanyaan keamanan.

Suatu Tempat Anda Berada

Berdasarkan lokasi Anda saat ini menggunakan GPS atau lokasi jaringan.



Sesuatu yang Anda Miliki

Smartcard, token USB/Bluetooth, atau benda lain yang Anda miliki.

Sesuatu yang Anda Adalah

Karakteristik fisik seperti sidik jari, pemindaian retina, atau suara.



Password Satu Kali (OTP)

TOTP

Password satu kali berbasis waktu menggunakan algoritma untuk menghasilkan kode dengan waktu saat ini.

HOTP

Password satu kali berbasis HMAC menggunakan nilai seed dan faktor bergerak seperti penghitung.

SMS OTP

Kode dikirim melalui pesan teks ke ponsel pengguna sebagai faktor tambahan.

Kode Statis

Kode yang dihasilkan sebelumnya dan sering dicetak atau disimpan di lokasi yang aman.

Biometrik



Faktor biometrik mengandalkan fisiologi unik pengguna untuk memvalidasi identitas mereka. Teknologi biometrik dinilai berdasarkan tingkat penolakan palsu (FRR) dan tingkat penerimaan palsu (FAR).

Akun

1

Identitas

Klaim tentang subjek

2

Autentikasi

Membuktikan identitas

3

Akun

Berisi informasi pengguna

4

Otorisasi

Menentukan akses

Mengklaim identitas dan diotorisasi untuk mengakses sistem atau layanan memerlukan akun. Akun berisi informasi tentang pengguna, termasuk hak dan izin yang terkait dengan akun tersebut.

Jenis Akun

1 Akun Pengguna

Dari akses dasar hingga pengguna dengan hak dan hak istimewa yang luas.

2 Akun Istimewa/Administratif

Seperti akun root atau anggota grup wheel pada sistem Linux dan Unix.

3 Akun Bersama/Generik

Sering dilarang oleh kebijakan keamanan karena masalah akuntabilitas.

4 Akun Tamu

Disediakan untuk pengguna sementara dengan hak istimewa yang sangat terbatas.

5 Akun Layanan

Terkait dengan aplikasi dan layanan, tidak boleh digunakan untuk login interaktif.



Penyediaan dan Penghentian Akun

1

Penyediaan

Akun dibuat dan sumber daya, izin, dan atribut lainnya diatur. Mungkin melibatkan pembuktian identitas.

2

Manajemen Izin

Memberikan hak yang tepat. Perhatikan masalah peningkatan izin yang terjadi seiring waktu.

3

Penghentian

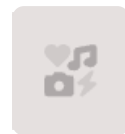
Menghapus akun, izin, dan data terkait. Penting untuk mencegah akun tidak aktif dimanfaatkan penyerang.

Manajemen Akses Istimewa



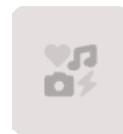
Izin Just-in-time

Izin yang diberikan dan dicabut hanya saat diperlukan, mencegah akses berkelanjutan.



Penyimpanan Password

Memungkinkan pengguna mengakses akun istimewa tanpa perlu mengetahui password.

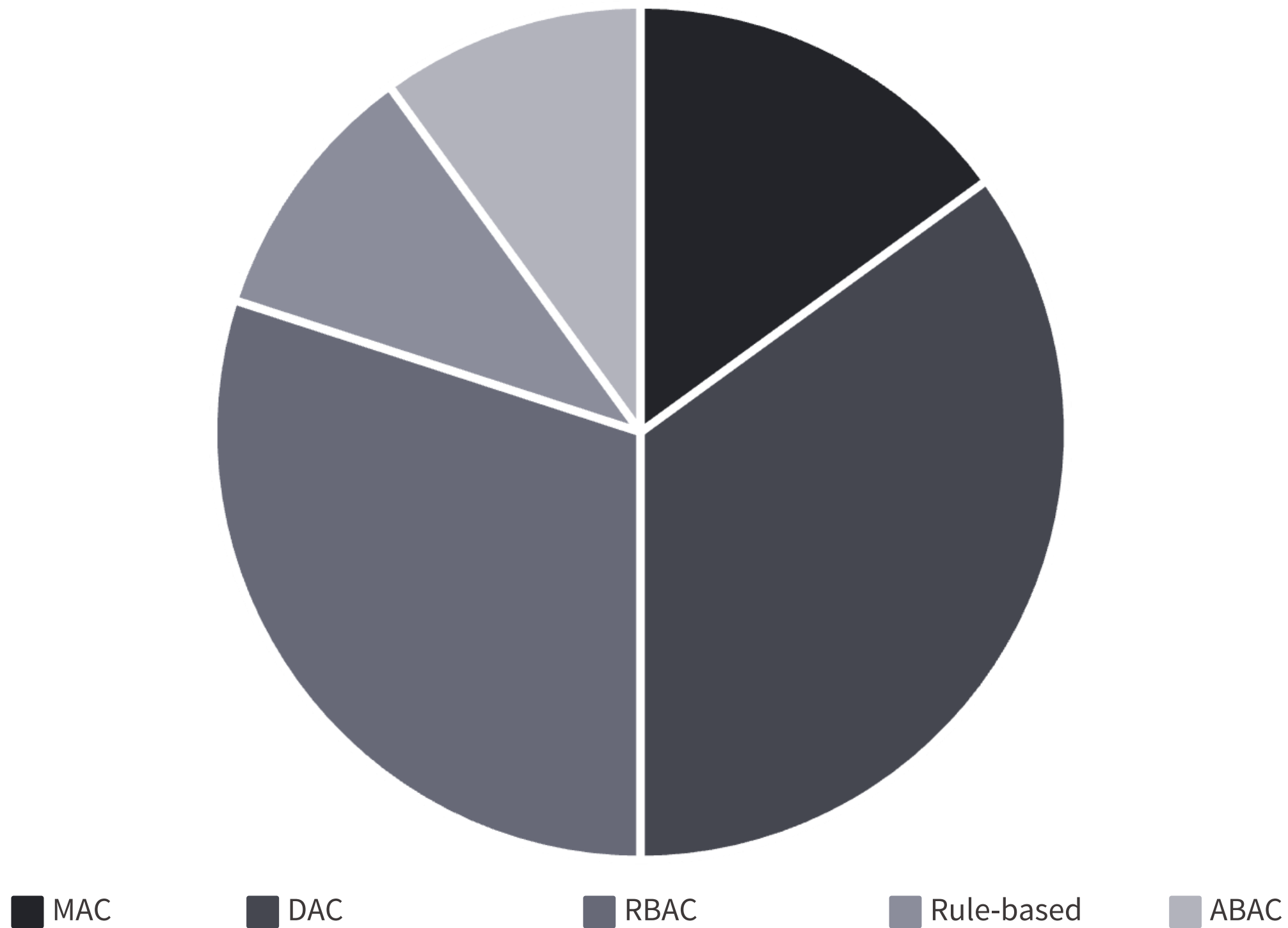


Akun Sementara

Akun sementara dengan masa pakai terbatas untuk tamu atau tujuan khusus.



Skema Kontrol Akses



Skema kontrol akses menentukan pengguna, layanan, dan program mana yang dapat mengakses berbagai file atau objek lain. Ini termasuk kontrol akses wajib (MAC), kontrol akses diskresioner (DAC), kontrol akses berbasis peran (RBAC), dan lainnya.

Izin Sistem File

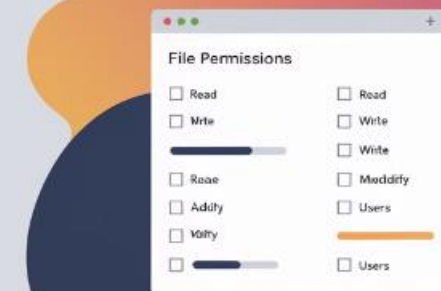
Linux

Izin ditampilkan dengan huruf drwxrwxrwx, menunjukkan apakah file adalah direktori, dan menampilkan izin pengguna, grup, dan dunia.



Windows

Izin dapat diatur menggunakan baris perintah atau GUI. Windows menyediakan kontrol penuh, modifikasi, baca & eksekusi, baca, dan tulis.





Ringkasan

1 Identitas dan Akses

Elemen kunci dalam keamanan organisasi. Autentikasi membuktikan klaim identitas, otorisasi memberikan hak yang diperlukan.

3 Autentikasi Multi-faktor

Membantu mengatasi masalah password seperti pencurian, penggunaan ulang, dan serangan brute-force.

2 Teknologi Autentikasi

Berbagai metode dan teknologi digunakan, termasuk SSO yang memungkinkan login sekali untuk banyak sistem.

4 Skema Kontrol Akses

Berbagai skema menentukan subjek mana yang dapat melakukan tindakan pada objek, dengan manajemen akses istimewa untuk pengguna administratif.